

This is the handout for the Cloud Bank Heist Lab supplemented by Framework

Rita Cyber Ed — Rita Sabri — Cardozo Education Campus

Name: _____ Date: _____ Period: _____

TODAY'S GOAL

By the end of this lab, you will be able to:

- Inspect a real-style cloud (AWS) environment and **find security misconfigurations**.
- Tell the difference between a true misconfiguration and a resource that is **public by design**.
- **Justify** every finding with evidence.
- Connect what you find to a **real cybersecurity career**.

WARM-UP — before you log in

Are you “secure” in a cloud environment?

1. A bank moves all its data to the cloud. In one sentence, what is the scariest thing that could go wrong?

2. A folder of files is set to “public.” Who can see it?

3. Quick prediction: of *S3 storage*, *IAM permissions*, *Lambda code*, *CloudTrail logging*, and *firewall rules* — which sounds scariest if it is set up wrong? Circle one. You will check your guess at the end.

Mission: You are the new **junior security analyst** at FirstTrust Bank. The bank just migrated to AWS. Your manager hands you *read-only* access to the production environment and one task: **find every misconfiguration before an attacker does**.

Methodology: There are **five** critical issues hiding in six services. Inspect each service carefully in the lab, then record what you found here. **One service is configured correctly**. If you flag it by mistake and you create a **false positive**, which costs a real security team time and trust.

Open the lab: ritasabri.github.io/rita-cyber-ed/cloudlab/ — Let us begin

Section A: The Audit — inspect, decide, justify

For each service: read what it is, think before you flag, inspect it in the lab, then record your decision and your evidence.

SERVICE 1: S3 Bucket: customer-data-prod

Object storage holding customer records and transaction data.

Think before you flag: Who *should* be able to read a folder full of customer SSNs? Now check the “Public access” setting — does it match who should have access?

What did you find? (List the settings that worried you.) _____

Your decision: Misconfiguration Configured correctly

Your evidence / reasoning: _____

DID YOU KNOW?

Real job: Cloud Security Engineer Work Role: Vulnerability Analysis (PD-WRL-007)

Finding exposed storage before attackers do is exactly this role — NICE defines it as identifying “deviations from acceptable configurations.” Banks, hospitals, and every major tech company hire for it. Typical range: \$110,000–\$160,000.

Maps to TKS: K1182 (policies & configurations) · S0532 (analyzing configurations) · T1118 (identify vulnerabilities)

SERVICE 2 — IAM Role: DeveloperRole

The set of permissions given to developers and engineering staff.

Think before you flag: What is the difference between giving someone the keys they *need* and giving them *every key in the building*? Look at the attached policies — and who is allowed to use this role.

What did you find? _____

Your decision: Misconfiguration Configured correctly

Your evidence / reasoning: _____

DID YOU KNOW?

Real job: Identity & Access (IAM) Specialist Work Role: Cybersecurity Architecture (DD-WRL-001)

“Least privilege” — giving people only the access they truly need — is a whole career. IAM specialists design who-can-touch-what for huge organizations. Typical range: \$95,000–\$140,000.

Competency: Access Controls (NF-COM-001). *TKS:* K0742 (IAM) · K0685 (access control) · S0569 (design security controls)

SERVICE 3 — Lambda Function: payment-processor

Serverless code that handles payment transactions. **Open the source code in the lab.**

Think before you flag: Where are the passwords and API keys stored? Is the *source code* a safe place to keep a secret that anyone with read access can see?

What did you find? _____

Your decision: Misconfiguration Configured correctly

Your evidence / reasoning: _____

DID YOU KNOW?

Real job: DevSecOps Engineer Work Role: Secure Software Development (DD-WRL-003)

Keeping secrets *out* of code — in a secrets manager, not the source — is core DevSecOps work: building security in *before* software ships. Typical range: \$120,000–\$170,000.

Competency: DevSecOps (NF-COM-008). *TKS:* K0814 (secure coding) · S0172 (apply secure coding) · T1197 (identify coding flaws)

SERVICE 4 — CloudTrail: production-audit-trail

The activity log for the *entire* AWS account — the record of who did what.

Think before you flag: If an attacker broke in tonight, would there be *any record* of it tomorrow? Check whether logging is actually on — and who turned it off, and why.

What did you find? _____

Your decision: Misconfiguration Configured correctly

Your evidence / reasoning: _____

DID YOU KNOW?

Real job: Cloud SOC Analyst Work Role: Defensive Cybersecurity (PD-WRL-001)

SOC analysts watch the logs to catch attacks as they happen — no logging means nothing to watch now and nothing to investigate later, which is why this may be the most dangerous finding of all. Works hand-in-hand with Incident Response (PD-WRL-003). Typical range: \$75,000–\$110,000.

Maps to TKS: K1131 (defense monitoring tools) · S0866 (log file analysis) · T1350 (continuous monitoring)

SERVICE 5 — Security Group: db-server-sg

The firewall rules protecting the production database server.

Think before you flag: Which “doors” (ports) are open, and *to whom*? Should a database be reachable by anyone, anywhere on the internet?

What did you find?

Your decision: Misconfiguration Configured correctly

Your evidence / reasoning:

DID YOU KNOW?

Real job: Cloud Network Security Engineer Work Role: Systems Security Analysis (IO-WRL-006)

Deciding which “doors” (ports) face the internet and which stay sealed is exactly this role’s job — implementing and maintaining the security of a running system. Typical range: \$120,000–\$180,000.

Maps to TKS: K0878 (network firewalls) · S0667 (assess security controls) · T1559 (resolve vulnerabilities)

SERVICE 6 — S3 Bucket: marketing-assets-public

A public bucket holding marketing materials, logos, and brand images.

STOP before you flag this one. It is *also* public — so it looks suspicious. But ask yourself: **what is inside it**, and is being public actually a *problem* here? A great analyst flags real issues and does *not* cry wolf on things that are public on purpose.

What did you find?

Your decision: Misconfiguration Configured correctly

Your evidence / reasoning:

DID YOU KNOW?

The skill you just used has a name: analyst judgment. Work Role: Defensive Cybersecurity (PD-WRL-001)

Knowing when *not* to flag is as valued as catching real issues. NICE lists it directly — *T1348: distinguish between benign and potentially malicious activity*. Crying wolf wastes a team’s time; good judgment is what separates a senior analyst from a junior one.

Section B: Analysis — think about your thinking

1. Of the five real problems, which do you think is the *most* dangerous? Why?

2. The marketing bucket was public, but it was *fine*. In your own words: what makes one public bucket a disaster and another one totally normal? (This is the most important idea in the whole lab.)

3. CloudTrail was turned off “to reduce costs” by an intern. Nothing was directly “exposed.” Explain why that one decision could still be the most dangerous of all.

4. A false positive — flagging something that is actually fine — has a cost too. What do you think happens to a security team that “cries wolf” too often?

Section C: Think–Pair–Share

THINK–PAIR–SHARE

Prompt: Almost every problem you found traces back to *one overworked intern* moving fast and cutting corners. **Whose job was it to prevent this** — the intern, the manager, or the company? Defend your answer with evidence from the lab.

THINK (*Piensa*) — On your own, write your position and one reason:

PAIR (*Comenta en pareja*) — Share with a partner. Where did you *disagree*? Write it down:

SHARE (*Comparte*) — Be ready to give the class your *strongest* reason out loud.

Section D: You're the Engineer — fix it

Now you are the cloud engineer. Pick *three* of the five misconfigurations and write a *specific* fix for each. “Add more security” is not an answer — name the setting you would change.

Finding	Your specific fix

Exit Ticket

EXIT TICKET

Claim — Evidence — Reasoning. If you could fix only *one* finding before you left the building tonight, which would it be?

CLAIM — The one finding I would fix first is:

EVIDENCE — What in the configuration proves it is dangerous?

REASONING — Why does fixing *this one first* protect the bank the most?

Self-reflection. How confident are you that you could audit a cloud environment on your own?

1 — 2 — 3 — 4 — 5

(1 = not yet 3 = with help 5 = I could teach it)

One thing I still have a question about: _____

Standards Alignment (verified against the NICE Workforce Framework for Cybersecurity v2.2.0)

NICE Work Roles: PD-WRL-007 Vulnerability Analysis · DD-WRL-001 Cybersecurity Architecture · DD-WRL-003 Secure Software Development · PD-WRL-001 Defensive Cybersecurity (with PD-WRL-003 Incident Response) · IO-WRL-006 Systems Security Analysis

NICE Competency Areas: NF-COM-001 Access Controls · NF-COM-008 DevSecOps

NICE TKS (by finding): S3 / PII: K1182, S0532, T1118 · IAM: K0742, K0685, S0569 · Lambda secrets: K0814, S0172, T1197 · CloudTrail: K1131, S0866, T1350 · Security group: K0878, S0667, T1559 · Analyst judgment: T1348

CIS: AWS Foundations Benchmark v3.0 (S3 public access, IAM least privilege, CloudTrail logging, security-group ingress).

OWASP: Top 10 (2021) — A05 Security Misconfiguration · A01 Broken Access Control.

AP CSP: Big Idea 4 (Computing Systems & Networks) · Big Idea 5 (5.6 Safe Computing).

PLTW Cybersecurity: Unit 2 (System Security), Unit 4 (Applied Cybersecurity).